REPUBLIC OF TUNISIA | Ministry of Higher Education and Scientific Research

Private Higher School of Engineering and Technology - ESPRIT - Al Baraka Bank Tunisia

Centre Urbain Nord, Avenue Cheikh Mohamed Fadhel Ben Achour, 1082 Tunis



ESPRIT
Private Higher School of
Engineering & Technology
Ariana - est. 2003



Al Baraka Bank
Your Partner Bank
Islamic Banking since 1983
44 branches - 5 IFN Awards 2024

INTERNSHIP REPORT | END-OF-STUDIES PROJECT

A Governed Intelligence for Islamic Banking

The Integrated RAGLab & Bank Assistant Platform

A retrieval-augmented system where every answer is traceable, every refusal is honest, and every decision is auditable - because in banking, a wrong rate is a legal risk.

Final-Year Engineering Internship | Software Engineering

Student	Farah AYARI - Private Higher School of Engineering and Technology (ESPRIT), Software Engineering
Host Organization	Al Baraka Bank Tunisia - Centre Urbain Nord, Avenue Cheikh Mohamed Fadhel Ben Achour, 1082 Tunis
Supervisor	**Mrs. Ahlem Ben Haddoud - Advisor, Al Baraka Bank (Centre Urbain Nord)**
Academic Year	2025 - 2026 ESPRIT | Engineering Degree

Architecture, integration and governance of a banking RAG platform - Two systems, one product, zero fabrication.

Trust through traceability - Every answer cites its source - Every refusal explains why

This report contains no account identifiers, repository URLs, or credentials. All figures are traceable to frozen benchmark artifacts.

Dedication

To my family, whose unwavering support made this journey possible,
to Mrs. Ahlem Ben Haddoud, whose guidance, rigor and trust shaped every decision in this work,
and to everyone who believes that technology, when governed, can serve trust.

Farah AYARI - ESPRIT, Engineering Student

Acknowledgments

I express my deepest gratitude to Mrs. Ahlem Ben Haddoud, my internship supervisor at Al Baraka Bank Tunisia - Centre Urbain Nord, for her availability, her precise feedback, and the clarity of her decisions. At every critical junction - from the choice of the corpus to the final engine switch - her judgment turned a technical possibility into a responsible banking feature.

I thank the teams of Al Baraka Bank for their welcome, the documents they entrusted to this project, and the operational feedback that revealed defects invisible in tests. I thank the faculty of ESPRIT for the training that made this project possible, and in particular for the emphasis on measurable engineering over mere demonstration.

Abstract - In One Paragraph

In regulated banking, a wrong answer about a rate, a fee or a deadline is not a minor inaccuracy - it is a legal risk. This internship delivered a complete, governed and measurable answer: an integrated platform where a bank-operated web application consumes a dedicated RAG (Retrieval-Augmented Generation) intelligence engine, both designed to never invent figures or rules. The platform comprises two cooperating systems: RAGLab, a document-grounded QA engine over four real Arabic banking documents, and Bank Assistant, a trilingual customer and staff web application (Angular 21 + Spring Boot 4 + PostgreSQL) that owns identity, quotas and audit and calls RAGLab over an authenticated, streaming-aware contract. Together they form a clean separation: the edge handles governance; the engine handles retrieval, grounding and generation - stateless, auditable and versioned.

Keywords: Retrieval-Augmented Generation | Islamic Banking | Grounded Answers | Citation Verification | Arabic NLP | Spring Boot | Angular | AI Governance

Note: This report contains no account identifiers, repository URLs or credentials. All figures are traceable to frozen benchmark artifacts. It is written around ideas and architecture, not a chronology.

Conter

1	Host Organization: Al Baraka Bank Tunisia	6
2	Project Vision: A Governed Banking Intelligence	7
3	System Architecture: The Full Picture	8
4	The Intelligence Engine - RAGLab: How It Thinks	10
5	The Digital Bank - The Web Application: How It Serves	12
6	Problems Solved: The Hard Parts & How They Were Fixed	14
7	Security, Privacy & Data Governance	16
8	Deployment & Operations	17
9	Results, Evaluation & Limitations	18
10	Conclusion & Perspectives	19
A	References & Appendices	20

How to read this report: Chapters 1-3 set the stage (who, why, how it fits). Chapters 4-5 are the technical core (engine + web app). Chapter 6 is the most important - it tells what broke and how it was fixed. Chapters 7-9 close with security, deployment and measured results.

CHAPTER 1

Host Organization:

Al Baraka Bank Tunisia - Centre Urbain Nord

Identity and History

Al Baraka Bank Tunisia is the first Islamic bank in Tunisia and the Maghreb. Created on 15 June 1983 as Beit Ettamouil Tounsi Saoudi (BEST Bank) by the Tunisian State and Sheikh Saleh Abdallah Kamel (founder of the Dallah Al Baraka Group), it was renamed Al Baraka Bank Tunisia in 2009 as part of the Group's identity unification. In 2013, it obtained approval to transform from a non-resident bank into a universal resident bank, allowing it to serve individuals, professionals and enterprises with Sharia-compliant products.

The Group, Al Baraka Group B.S.C. headquartered in Bahrain Bay, operates over 600 branches in 12 countries (Jordan, Egypt, Tunisia, Sudan, Bahrain, Turkey, South Africa, Algeria, Lebanon among others) and pioneered participative finance worldwide. Today the bank operates 44 branches across Tunisia, headquartered at Centre Urbain Nord in Tunis - one of the capital's largest economic hubs - and has been elected Best Islamic Bank in Tunisia (2018, 2019, 2021) with five IFN Awards in 2024.

A Sharia-Compliant Product Universe

All offerings operate within Tunisian Law No. 2016-48 of 11 July 2016 on banks and financial institutions (Articles 12-16 define Islamic operations) and Central Bank Circular BCT 2019-08 - two documents that form the very corpus this project indexes.

Family	Products
Trading & Investment	Murabaha (cost-plus), Salam (deferred delivery), Istisna'a (manufacturing), Mudaraba / Musharaka (partnership), Sukuk, participative deposits
Leasing & Financing	Ijara with acquisition option, Beit Al Baraka (home), Tas'heelat (personal), equipment & working-capital financing
International & Daily	Documentary credits, remittances, leasing, day-to-day banking

Product families at Al Baraka Bank - the same products the assistant must explain without error.

The Internship Site

Al Baraka Bank - Centre Urbain Nord (Operational Heart)

Avenue Cheikh Mohamed Fadhel Ben Achour, Centre Urbain Nord, 1082 Tunis - Tel: (+216) 71 183 203 | Head office: +216 71 18 65 00 | SWIFT: BEITTNTT

The Centre Urbain Nord is not merely an address; it is the bank's operational heart, where product, compliance and IT decisions converge - and where this project was supervised by Mrs. Ahlem Ben Haddoud. The location matters because the work was shaped daily by real product questions, real compliance constraints and real customer language.

The bank's visual identity (Al Baraka brand tokens: Red #E0122F + Orange #F5881C) drives the entire front-end design system.

CHAPTER 2

Project Vision:

A Governed Banking Intelligence

The Business Problem

Three tensions motivated the project. First, the user's question is rarely the document's question: a customer asks in everyday language ('can I open a shop?') where the corpus uses technical terms (sigha, mahal al-aqd, tamwil). Second, multilingual asymmetry: the corpus is Arabic, but questions arrive in French and English, and a French question must be answerable from an Arabic passage without translating either. Third, errors are costly: a false rate, deadline or sanction is a legal exposure, not a minor imprecision.

The North Star: Five Properties

#	Property	What it means in practice
1	Grounded & Auditable	Every answer traceable to a source; nothing fabricated about rates or terms
2	Compliant	PII scrubbed on output; no learning from customer chats
3	Quota-Controlled & Secure	Public channel metered; intelligence engine never on Internet
4	Regulable by Staff	Admins edit taxonomy, governed facts and documents
5	Multilingual (RTL first)	French / Arabic / English; Arabic RTL as first-class citizen

Five properties governed every technical choice, in strict priority order.

What Was Delivered: Two Systems, One Product

Deliverable in One Sentence

RAGLab answers; Bank Assistant serves customers and governs what RAGLab knows. Neither writes into the other's store. Staff sees every conversation from its first message (Java persists before calling the engine), and a customer never sees which document an answer came from. That boundary is what makes the answer path auditable.

The web app exposes a public landing page, a floating assistant widget, an authenticated client portal (accounts, cards, transactions, financing simulations, advisor appointments) and an eleven-screen admin back-office including a five-tab RAGLab Console. The intelligence engine is a versioned, stateless HTTP microservice with 25+ routes, a frozen contract and a full audit trail.

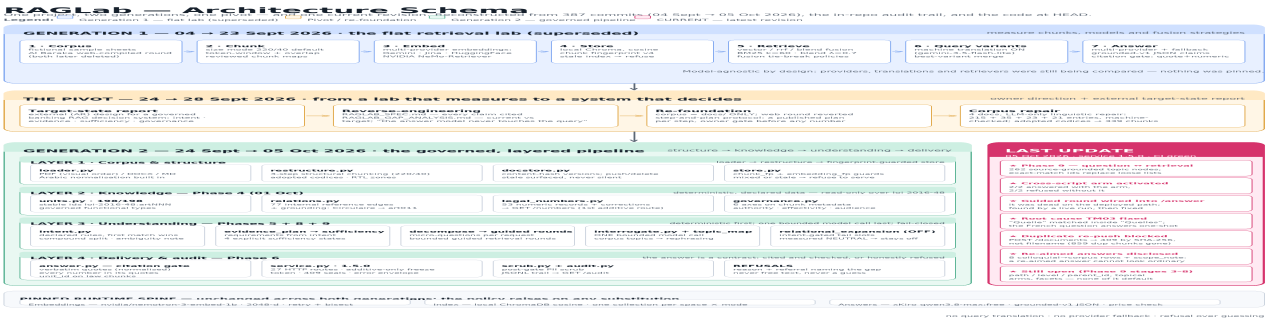
The rest of this report explains how the two fit together, how the engine decides, how the app governs, and - most importantly - what broke and how it was fixed.

CHAPTER 3

System Architecture:

The Full Picture - From Browser to Intelligence

End-to-End Flow



Full architecture: from browser to intelligence. Generation 1 (flat lab) - pivot - Generation 2 (four governed layers) - current update. The engine is external and addressed by ip:port.

In words: the browser talks only to nginx (Angular SPA, security headers, SSE). Nginx proxies /api to the Spring Boot edge (Java 21) which owns authentication (JWT), roles, quotas, persistence and admin. The edge calls RAGLab over an authenticated internal contract (X-Service-Token) and streams the answer back. PostgreSQL (Flyway, ddl-auto=validate, 15 migrations, single writer) holds the business schema. The vector index lives inside the Python agent - no shared-DB write coupling.

Why This Separation Is the Design

The split is not a convenience; it is the guarantee. The business schema can evolve without re-indexing; the index can be rebuilt without migrating the business database. The edge opens the exchange row before calling the engine, so even a failure is visible to staff; the engine is stateless and returns provenance that the edge records. An admin switching the engine, a document re-published, or a model key rotated all flow through explicit, audited actions.

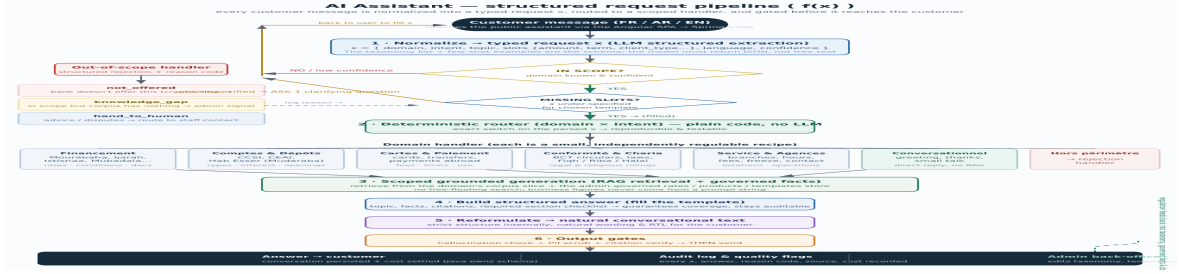
Technology Stack at a Glance

Layer	Choice	Why this, not that
Frontend	Angular 21 (standalone), Vitest, Inter	SPA with lazy modules; no Google-fonts build dependency
Backend Edge	Java 21, Spring Boot 4, Flyway, JWT, virtual threads	Owns schema with validate; avoids carrier pinning
Intelligence	Python 3.11, FastAPI + uvicorn, explicit code	No LangChain/LlamaIndex - every behavior readable
Vector Store	ChromaDB local (cosine) + BM25	Local avoids cloud cost & banking-data egress
Embeddings / LLM	NVIDIA nemotron-3-embed-1b (2048-d) + Qwen	Measured best on Arabic; zero fallback
Persistence	PostgreSQL, Redis queue, Flyway	Single owner; durable BRPOP queue
Deployment	Docker Compose, offline tarball	Same images dev to prod; Windows-native path

Stack choices: sobriety is a governance decision - no orchestration framework, no external vector DB, no vendor SDK.

The Two Lifecycles

- Document lifecycle: pushed via POST /documents (content-hash versioned; identical bytes = no-op; SHA-256 dedup guard), then batch-indexed via POST /ingest (one job at a time; 409 is a state, not an error). The edge's documents table holds a parallel record but no longer drives indexing - RAGLab owns its index and reports pending / indexed / stale honestly.
- Conversation lifecycle: browser -> edge (quota gate) -> RAGLab (retrieval -> generation -> gate) -> edge (scrub -> persist -> settle quota -> stream). The edge opens the row before calling the engine so even a failure is visible.



Customer chat path: two-phase metering, streaming relay and persistence. The edge is the single writer; streaming is end-to-end (Python -> Java -> browser).

CHAPTER 4

The Intelligence Engine:

RAGLab - How It Thinks

Corpus and the Arabic Challenge

Document	Role	Fragments
Law 2016-48 (198 articles, 11 titles)	Superior legal reference	233
BCT Circular 2019-08 (20 chapters)	Operational framing	13
Internal Islamic Operations Guide	Internal policy & compliance	54
Intro to Islamic Finance (Madkhal)	Training, definitions	39
Total	4 real Arabic documents	339

The governed corpus: four real documents => 339 structure-aware fragments.

The PDFs are scanned legal Arabic: visual-order lines, reversed word order, corrupted digits, broken headings. Indexed directly, the corpus is nonsense. The fix is linguistic, not algorithmic (Chapter 6 tells how).

Structure-Aware Chunking

Two chunkers are implemented and measured. The legacy size mode (220 tokens + 40 overlap) remains; the adopted restructure mode dominates via three explicit steps: (1) semantic normalization - gazette header cleanup, repeated-header dropping (>=3 occurrences), section-marker extraction (al-fasl / al-bab / al-qism), visual-order repair by zone, hierarchy into Markdown; (2) breadcrumb enrichment - injecting h1 > h2 > h3 ancestry above every heading/table so a chunk carries its context; (3) recursive structural splitting over ['\n# ', '\n## ', '\n### ', '\n\n', '\n', ' '] at the same 220/40 budget. Each chunk carries an identity card: document, chunk_index, heading, language, section_type, chunk_fp (fingerprint v4), embedding_fp, embedding_model.

Measured Impact

Structural chunking gains +20 points of hit@1 over window splitting (live: 51 -> 71; offline BM25: 42 -> 62). This single change outranked every retrieval-mode experiment and became the foundation for everything above it.

Embeddings and Storage

- Model: nvidia/nemotron-3-embed-1b, native 2048 dimensions, via NVIDIA Build endpoint (batch 32, exponential backoff + Retry-After, bisect on degenerate vectors, resumable JSON cache).
- Store: one ChromaDB persistent collection per (embedding-space x chunking mode), hnsw:space=cosine. BM25 lexical index maintained in parallel for hybrid modes.
- Fingerprint guard: chunk_fp + embedding_fp stored per chunk; retrieval over a stale collection is refused before any model call with remediation instructions. No mixed indexes are ever served.

Retrieval: Dense Wins

Mode	hit@1	hit@3	hit@5
vector (dense, default)	71	80	87
rrf (BM25 fused, k=60)	71	80	82
blend (lambda=0.7)	62	80	84

Retrieval modes measured identically (live models, 50 questions). In French: dense 50/67/67 vs RRF 33/33/50 - dense stays default.

Decision: dense stays default; others remain explicit options, never silently blended. A deterministic feature-based reranker (62/82/87 -> 62/89/89 offline) provides a cheap second pass.

Understanding the Question

Module	Function
intent.py	Rule-based intent classification (first rule wins); splits compound requests; detects ambiguity
evidence_plan.py	Derives evidence requirements (what must be present) - never the answer
sufficiency.py	Confronts plan vs fragments; emits sufficient / insufficient / contradictory
interrogate.py + topic_map.py	Only when nothing is covered: one bounded LLM call re-expresses the practical question as the nearest technical question (262-node map)

Understanding layer: deterministic first, model second, never twice. Interrogation is fail-closed with full disclosure.

Delivery: Citation Gate and Audit

- Prompt (grounded-v1): question + sources declared untrusted data; model has no account, no tools; output is strict JSON with claims + evidence; quotes >=12 chars, contiguous, verbatim.
- Three-gate verification: (i) quote membership - normalized quote must be substring of cited source; (ii) numeric gate - every number in a claim must appear in its quotes (Arabic-Indic handled); (iii) policy gate - source must be retrieved, allowed and in force.
- Sufficiency commitment: nothing covered -> refuse before generation, naming missing requirements; partial -> one bounded regeneration. PII scrubbing after the gate (EMAIL/PHONE/RIB-IBAN/CIN -> [LABEL]); audit trail via GET /audit (500-entry cap) correlated by X-Request-Id / X-Turn-Id.

Knowledge Layer on Law 2016-48

- 198 knowledge units (= 198 articles), literal text, stable ID loi-2016-48:artNNN, hierarchical path. 77 internal cross-references + 1 anchoring relation (Circular -> Article 11). 53 structured number records (14 rates, 28 deadlines, 5 caps, 6 sanctions) via GET /numbers - the first additive-only endpoint under the freeze. 6 governance axes on fragment metadata.

Impact of the Knowledge Layer

A unit-description index answers law questions at 100/100/100 (hit@1/3/5) vs 67/92/92 baseline - every law question, including cross-lingual, finds its article at rank 1. This proves that structure beats scale: 198 well-formed descriptions beat thousands of overlapping windows.

CHAPTER 5

The Digital Bank:

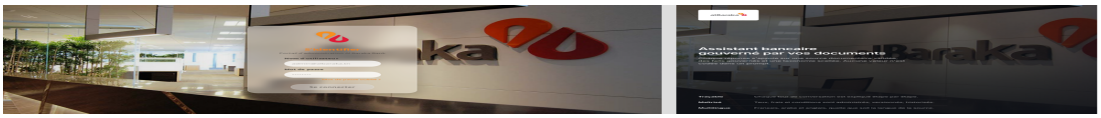
The Web Application - How It Serves

Overall Shape

The web app is the only public edge. RAGLab is never exposed to the Internet; it is addressed by ip:port on a private network with a shared X-Service-Token. Frontend: Angular 21 (standalone, lazy modules) - public landing page (/), chat widget, authentication, client portal, admin back-office under /admin/**. Backend: Spring Boot 4 (Java 21) - JWT, Flyway migrations, quotas, persistence, monitoring, five-tab RAGLab Console. Database: PostgreSQL, Flyway single-owner (V1 ... V15), ddl-auto=validate. No second writer.

Customer Experience

- Landing page at /: trilingual hero, products, assistant showcase, services, FAQ, footer - brand tokens from Al Baraka palette (Red #E0122F, Orange #F5881C) with full RTL support. A floating assistant widget offers the same SSE endpoints with its own session, without login, quota-limited.
- Authentication split: Client vs Staff tabs on login, role-based redirect, registration at /register. Client portal /portal: accounts, cards, transactions, financing simulations, advisor appointments, profile, and a ChatGPT-style assistant carrying the client's own conversation history.



Portal identity: dedicated Client vs Staff login - the split that makes role-based redirect and customer-data isolation possible.



Client dashboard: accounts, cards and transactions in one place - the same data that the masked context summarizes for the assistant.



Chat answers: grounded responses with structured citations vs honest refusals - never a guess.

CORE BANKING DATA MODEL (V15)

Domain	Tables & Key Fields
Identity & Risk	clients (CIN, ABK######, segment, langue_preferee, KYC, risk, branch agence_id)
Money	comptes (IBAN, RIB, solde, decouvert_autorise), cartes (masked porteur e.g. 4571 **** **** 6842, no PAN/CVV), transactions
Products	financements (murabaha/ijara, amounts, margin, installments), beneficiaires (RIB, bank)
Service	advisor_requests (motive, branch, date/time, free-text), conversations, messages

Customer domain: realistic core-banking shape. No full card numbers stored. Transactions may contain third-party personal data (store names) - DPIA-relevant.

Two design facts matter: transactions may contain third-party personal data, and the assistant never sees raw balances - for a signed-in customer, a masked context (CustomerContextService) is derived at call time: slices and categories only, no direct identifiers leave the bank.

Authentication, Roles and Quotas

- JWT with server-side rotation: access <=1h; refresh tokens carry jti in a family, single-use (rotated) with reuse detection (consumed jti burns the family -> 401). Revocation on logout and on any admin role change / deactivation / delete.
- Dynamic staff roles: admin_roles + admin_permissions + role_permission + admin_access_audit (Flyway V14). Twelve fixed permissions; SUPER_ADMIN reserved; unknown role -> fail-closed 403; every change audited with mandatory reason.
- Two-phase metering: gate() before the engine, settle() after. Anonymous: 3 000 tokens / 20 messages; authenticated: 10 000 / 50; max 5 new sessions/hour. Per-session striped ReentrantLocks (64 stripes, not synchronized) so a slow engine cannot be gamed - and because the backend runs on JDK 21 virtual threads, this avoids carrier pinning.

Streaming and Persistence

End-to-end streaming: Python GroqCompletion.stream -> Java AgentClient.invokeStream (pinned to HTTP/1.1) -> Java SSE relay POST /api/chat/message/stream -> browser fetch + ReadableStream parser. Fallback to classic POST /message; abort cleanly cancels. Persistence: Java is the single writer. It opens the exchange row before calling RAGLab, persists after streaming, writes attribution (engine = RAGLab) and provenance, and sends the last 10 turns as context to the stateless engine (turn_id + X-Turn-Id for idempotency).

Admin Console: The Control Room

Screen	Function
/admin/facts	Governed facts CRUD - rates/fees/eligibility outrank any document; audit append-only
/admin/taxonomy	Exemplar & release management; seal() freezes numbered release; publish rollback
/admin/agent/health	Effective RAGLAB_URL (overridable by SUPER_ADMIN, audited), live probe
/admin/agent/quality	Quality workbench: answer -> retrieval -> quote-existence, all verbatim
/admin/agent/documents	One drop zone, two chunk worlds (honest pending/indexed/stale)
/admin/agent/config	Models & keys (write-only, CONFIG_SET audited) - RAGLab settings read-only
/admin/agent/journal	Every admin action, filterable by action, searchable, with motive column
/admin/agent/monitor	Live feed + KPI strip (grounded rate, refusal reasons) over last 200 exchanges

Admin control room: every write is audited, every read is role-gated. The back-office stays in French (internal staff).

CHAPTER 6

Problems Solved:

The Hard Parts & How They Were Fixed

This chapter is the heart of the internship: not what was planned, but what broke - and what architecture prevents it from breaking again. Each problem below was solved with a measurable fix and a regression test; none was patched silently.

Arabic PDFs Are Not Text	
Problem:	Scanned legal Arabic extracts in visual order (right-to-left lines as rendered, not logical order), with split words, repeated gazette headers/footers and every digit corrupted. Indexed directly, the corpus is nonsense.
Fix:	Dedicated restructure.py pipeline: NFKC + Arabic presentation-form repair, alef/yah unification, tatweel stripping, page-header cleanup and repeated-header dropping (>=3 occurrences), section-marker extraction (al-fasl / al-bab), and visual-order reconstruction by zone into logical order before chunking. Linguistic repair was performed batch by batch (29 batches for the law: 215 corrections; then 35, 23, 21 for the other docs), each checked by llm_repair_check.py and adopted after supervisor sign-off. Raw docs/ files are never modified; corrected codices are applied inside the pipeline and versioned in raglab/audits/.

A 220-Token Window Destroys Meaning	
Problem:	Fixed-window chunking (220 tokens + 40 overlap) cuts a legal article mid-definition, making the passage unverifiable and retrieval noisy.
Fix:	Structure-aware chunking (semantic normalization -> breadcrumb enrichment -> recursive structural splitting) gains +20 points hit@1 (51 -> 71 live; 42 -> 62 offline). This single change outranked every retrieval-mode experiment and became the foundation for everything above it.

Searching in Arabic With French/English Questions	
Problem:	Users write technical terms in Latin script (murabaha, sukuk) while documents use Arabic script. Lexical search has zero overlap; vector search may miss without a bridge.
Fix:	Layered: native multilingual embeddings (NVIDIA 2048-d) handle most cases; declared cross-script bridges (curated Latin->Arabic, df-checked so a bridge onto boilerplate can never anchor evidence); colloquial concept vocabulary (e.g., hana/khamara/bar -> khamr, qimar/casino -> maysir) with scope disclosure; and one bounded interrogation call that rewrites a practical question into the nearest technical question, re-evaluated deterministically.

The Guided Retrieval Round Was Dead in Production	
Problem:	Sufficiency controller was called without a search function, so the guided rescue round never executed in production - only in offline tests.
Fix:	Live service now passes the search callable. This established the rule: any claim about the deployed service must be verified on the deployed service. A regression test now covers the deployed path, not just the unit path.

The Index Was Silently Duplicating	
Problem:	Re-pushing an identical document created duplicates (859 of 1 713 observed), inflating term frequencies and corrupting retrieval. Legacy append-only path had no guard.
Fix:	RAGLab SHA-256 content-hash 409 guard (document_already_in_corpus, byte-identical = no-op); batch POST /ingest as one-job-at-a-time; POST /documents content-hash versioning (identical bytes = no-op; different = version bump). In-house path fixed similarly: delete_source purges by collection + jsonb before upsert.

French Intent Misclassified by a Substring	
Problem:	Regex Quelle matched inside Quelles, misclassifying a procedural question as definitional.
Fix:	Anchored markers + dedicated French procedural patterns, covered by live-set regression tests.

Streaming Broke on HTTP/2 Upgrade	
Problem:	java.net.http.HttpClient defaults to HTTP/2 and sends Upgrade: h2c; uvicorn rejected it with 422. Browser saw a broken stream.
Fix:	Pin AgentClient.invokeStream to HTTP/1.1 explicitly. One-line cause, days of debugging - and a clear lesson: infrastructure defaults are product decisions.

Two Sensitive Configuration Errors (Real Incidents)	
Problem:	Hardcoded X-Service-Token in Compose silently overrode the operator's environment variable; network errors leaked as 500, hiding provider failures; nginx cached the wrong index.html.
Fix:	Env composition priority fixed (operator env wins); network errors now 502 with scrubbed detail; index.html no-cache + critical-CSS disabled. All three are regression-tested; the token incident was a real platform-team occurrence, not a hypothetical.

CHAPTER 7

Security, Privacy

& Data Governance

Defense in Depth

Layer	Mechanism
Network	Only nginx is public; backend + Postgres + RAGLab on private network; edge TLS + HSTS
Authentication	JWT (>=256-bit, never in repo); X-Service-Token constant-time hmac.compare_digest
Authorization	All admin @PreAuthorize; DB-backed staff permissions; client UTILISATEUR isolated; unknown -> 403
Input	Filename validation; 20 MiB cap -> 413; enum validation -> 400
Prompt Injection	System prompt declares Q+A as untrusted data; capability guard refuses live-data requests locally
Output	PII scrub after gate: EMAIL/PHONE/RIB-IBAN/CIN -> [LABEL]
Secrets	Env / platform secrets only; GET /keys presence + fingerprint; POST /keys rejects placeholders

Security layers: each one is small; together they are complete. No layer is trusted alone.

Personal Data: What We Hold, What We Do Not

The platform holds nine families of customer personal data across clients, comptes, cartes, transactions, beneficiaires, financements, advisor_requests, conversations, refresh_tokens - from direct identifiers (email, CIN) to financial (IBAN/RIB) to free-text (chat, appointment messages). Two truths matter:

- Nothing identifiable leaves the bank beyond a masked slice/category context built at call time for an authenticated customer asking about their own situation.
- The highest real risk is free text: a question may contain an account number; it is stored verbatim and shown to staff. The output scrub + audit mitigate; a retention/deletion lifecycle remains a documented pre-production gap with the legal team.

No full card PAN or CVV is ever stored. Transactions may contain third-party personal data (store names) - a DPIA-relevant nuance. This transparency is deliberate: the Customer PII Report (CUSTOMER_PII_REPORT.md) lists every field, who writes it and who may see it.

Audit and Traceability

- Every answer carries citations and engine attribution (RAGLAB_*); every admin action is written to agent_admin_audit with mandatory reason; every ingestion writes JournalIngestion; every conversation is visible from its first message.
- Monitoring KPIs (grounded rate, refusal reasons) over the last 200 exchanges attribute by engine even for historical turns - no new column needed, the intent tag carries the provenance.

Threat Pass

A 20-point checklist (THREAT_PASS_6.2.md) drove concrete fixes: second unauthenticated chat door removed, string compares hardened to constant-time, hardening headers at nginx + Spring, Swagger off in prod, host ports bound to 127.0.0.1. Remaining documented gaps: magic-byte sniffing, per-request DB auth vs hourly rotation, Redis auth, nightly purge of expired refresh tokens.

CHAPTER 8

Deployment & Operations

One Image Set, Three Environments

	dev	staging	prod
How	docker compose up	same images, real TLS	same images, HA stores
Profile	(default)	prod	prod
Swagger	on	off	off
Logs	plain / json	ecs	ecs
Secrets	.env (local)	platform secrets	platform secrets
Data	throwaway	anonymized monthly	live

Promotion moves image digests dev -> staging -> prod; never rebuild for prod.

deploy/promote.sh enforces it: refuses a dirty tree, tags with commit SHA (never latest), and verify compares GET /actuator/info + GET /version.json against HEAD. Docker-compose.prod.yml (per host) sets prod profile, removes host port mappings, and points at secret files. Kubernetes translation is one-to-one.

Topology

- Internet --443(TLS at edge, HSTS)--> Edge Proxy (Traefik/nginx/LB) --80(private)--> frontend (nginx SPA) --/api--> Spring Boot --> RAGLab (private, never published) --> Postgres (PITR: daily full + WAL, 30-day retention, quarterly drill). Only the edge proxy has a public address.
- Flyway runs at backend boot; migrations V1 ... V15 are expand->migrate->contract; a non-idempotent V1 was rewritten and baselined at 0 - the fix that makes the migrations CI job possible at all.

Deploy Procedure

```
TAG=v1.0.0 docker compose -f docker-compose.yml -f docker-compose.prod.yml pull
docker compose -f docker-compose.yml -f docker-compose.prod.yml up -d backend
docker compose logs backend | grep -E "Flyway|Migrating|Successfully"
docker compose -f docker-compose.yml -f docker-compose.prod.yml up -d frontend
E2E_BASE_URL=https://assistant.example.tn ./e2e/run.sh
```

Observability

- Correlation: turnId minted once in Java, sent as body + X-Turn-Id, bound to MDC and Python contextvar - one grep spans both services; X-Request-Id echoed on every response.
- Metrics: backend GET /actuator/prometheus -> chat_turns_total / chat_turn_duration; Python GET /metrics -> agent_turns_total. OpenTelemetry tracing is the documented next step.
- Runbooks: RUNBOOK.md covers incidents, ingestion, rotation, regulatory audit queries. HOST_TESTING.md + docker-compose.test.yml give a one-command full-stack test on a workstation (seeded accounts: staff at every permission level, four customers with accounts/cards/movements/financings).

CHAPTER 9

Results, Evaluation

& Limitations

How Quality Is Measured

- questions_50.json - 50 cases: 10 verbatim, 20 paraphrases, 15 cross-lingual (6 FR + 9 EN), 5 out-of-scope. 32 AR / 8 FR / 10 EN. Expected document + substring verified as distinctive per document.
- questions_targets.json - 10 Arabic cases: 2 per category (colloquial, synonyms, implicit, compound, ambiguity). Rules: paired comparison in same run; +-2 pp tolerance across runs; a frozen set is never edited to improve a result; offline BM25 filters cheaply, live runs decide.

Headline Results

What	Result
Chunking (live, 50)	size 51/64/71 -> restructure 71/80/87 (hit@1/3/5) - +20 pp
Retrieval (restructure)	dense 71/80/87 > RRF 71/80/82 > blend 62/80/84 - dense default
Reranker (offline)	62/82/87 -> 62/89/89 - activated
Knowledge unit index (law)	67/92/92 -> 100/100/100 - every article at rank 1
Target categories	compound 100 | implicit+ambiguous 50/100 | synonyms 50 | colloquial 0
Model independence	agreement 0.720; Jaccard of sources 1.000 - divergence is accept/refuse
Final campaign	retrieval 5/7 | topic map 5/5 | 3 answered / 3 refused, zero errors
Robustness (6 adversarial)	Fabricated/borrowed/computed/unknown-marker/injection - all rejected
Tests & CI	472 unit + 133 offline | 8 workflows | 469 hard-harness families | green at merge

Results that are measured, not claimed. All numbers from frozen artifacts, not impressions.

What the System Does Not Do (Yet)

Limitation	Scope
Citation existence != entailment	Gate proves words/numbers come from source, not that claim follows logically
No similarity threshold	Top-5 transmitted even if off-topic; safety rests on sufficiency + refusal
Single worker	One profile/index/ingest at a time; horizontal scale is designed, not deployed
Updates by re-ingestion	Old fragments serve until next ingest (now surfaced as stale)
Evaluation scale	50 + 10 cases small & correlated - not a security/legal guarantee

Readiness Statement (from the repository itself)

Suitable for a supervised pilot on approved non-confidential documents; not ready for unsupervised customer-facing banking advice. This honesty is not a disclaimer - it is a product property. The system refuses rather than guesses, and its limits are documented where any bank auditor can read them.

CHAPTER 10

Conclusion

& Perspectives

What Was Built

A working, documented and measurable platform: a complete language pipeline (reading and repair, structure-aware chunking, vector + lexical indexing, dense retrieval, intent and sufficiency reasoning, citation-gated generation, output scrubbing, audit) wrapped in a bank-operated web app that owns identity, quotas and persistence - all measured, versioned and traceable.

Lessons That Outlive the Code

- Measurement replaces opinion. Every structural choice - restructure over window, dense over fusion, lexicon off, relational expansion abandoned - was settled by paired numbers, and several reasonable intuitions were rejected by data.
- Governance of decisions is architecture. The step-and-plan protocol, activation gates and frozen question sets allowed the project to survive interruptions without silent regression and to distinguish progress from displacement.
- Reality is the only judge. The most expensive defects - the inert guided round, the French intent misclassification, index duplication - were invisible in tests and obvious in operation. Any claim about the deployed service must be checked on the deployed service.

Next Steps

- Per-document authorization and chunk-level topical metadata (path / level / parent_id) before any production re-index.
- Topical & faceted retrieval arms measured on frozen sets, fused with dense - without reintroducing known regressions.
- Closing measurement campaign - re-measure every arm, document limits, then decide defaults.
- Industrialization: multi-user semantics, incremental updates, observability (metrics + tracing), adversarial evaluation, upload magic-byte validation, OpenTelemetry, and a legal-team-reviewed retention/deletion lifecycle.
- Product: safely editable answer templates and conversation quality flags in the control room.

"The best system we built is not the one that answers the most questions,
but the one that knows when not to answer - and can prove why."

Farah AYARI, ESPRIT - Al Baraka Bank Tunisia, Centre Urbain Nord - supervised by Mrs. Ahlem Ben Haddoud

RAGLab/README.md	Supported pipeline, measured A/B tables, run instructions
RAGLab/RAGLAB_SPEC.md	Reverse-engineered specification (Observed / Inferred / Unknown)
RAGLab/RAGLAB_GAP_ANALYSIS.md	Target-state gap analysis (ahead / behind per capability)
RAGLab/RAGLAB_ROADMAP.md	Binding execution plan - step-and-gate protocol, decision log
RAGLab/raglab/CONTRACT.md	Frozen HTTP contract (behaviors, states, error envelope)
RAGLab/raglab/SERVICE.md	Service operation guide & env
bank-assistant/README.md	Web-app overview & governance model
bank-assistant/PLAN_TO_PROD.md	Phased plan (phases 0 -> 10)
bank-assistant/docs/DEPLOYMENT.md	Deployment topology & promotion
bank-assistant/docs/CUSTOMER_PII_REPORT.md	Customer PII inventory & gaps
bank-assistant/docs/THREAT_PASS_6.2.md	20-point security checklist
bank-assistant/docs/PROJECT_REPORT.md	Full history of the web app (255 commits)
RAGLab/RAGLAB_FULL_REPORT.md	Full history of the engine (376 commits)
Corpus: RAGLab/docs/	Loi 2016-48, BCT Circular 2019-08, Guide, Madkhal - 4 real documents

Institutional Sources Consulted

- Al Baraka Bank Tunisia - Official Website (albaraka.com.tn): history, Centre Urbain Nord headquarters, 44 branches, IFN Awards, product catalog.
- Law 2016-48, Official Journal of the Tunisian Republic No. 58 of 15 July 2016; CMF legal reference site.
- ESPRIT - Private Higher School of Engineering and Technology, Ariana (2003), accredited by the Ministry of Higher Education; CTI EUR-ACE audit 2023.

Term	Transliteration	Meaning
Al-murabaha	al-murabaha	Cost-plus sale with disclosed capital and margin
Al-ijara	al-ijara	Lease with acquisition option (Sharia-compliant)
Al-sigha	al-sigha	Contractual form (offer & acceptance)
Al-fasl	al-fasl	Article (law) / chapter (circular)
Nafidh	nafidh	In force
Kafin	kafin	Sufficient (evidence)
Ghayr kafin	ghayr kafin	Insufficient
Muta'arid	muta'arid	Contradictory (two sources in conflict)
RAG	-	Retrieval-Augmented Generation
hit@k	-	Whether expected document/fragment is in top-k
RRF	-	Reciprocal Rank Fusion
BM25	-	Lexical ranking function
Citation gate	-	Quote membership + numeric gate
Sufficiency	-	Whether evidence satisfies the proof plan

Note: Arabic terms are transliterated here so the PDF renders on standard fonts; the Markdown version preserves the original script where the platform font allows it.

Appendix B - Key Figures

Fact	Source
RAGLab: 376 commits, 249 files, 86 modules, ~40.8k lines	Git history & RAGLAB_FULL_REPORT.md
Corpus: 4 docs -> 339 fragments (233/54/39/13)	raglab/audits/MASTER_INDEX.md
Tests: 472 unit + 133 offline, 8 workflows	CI at merge (service v1.5.0)
Web app: 255 commits, 428 files, 15 migrations	bank-assistant/docs/PROJECT_REPORT.md
Stack: NVIDIA 2048-d + Qwen (pinned, no fallback)	raglab/pipeline_policy.py
Hit@1 live: 71/80/87 (restructure) vs 51/64/71 (size)	questions_50.json frozen set

Appendix C - Reproduction (Local)

```
# RAGLab
cd RAGLab/raglab
python3 -m venv .venv && source .venv/bin/activate
pip install -r requirements.txt
./run_tests.sh --offline
python main.py ingest --reset --data-dir ../docs
python main.py answer "..." --query-lang ar

# Web app (Docker)
cp bank-assistant/.env.docker.example .env   # set RAGLAB_URL, RAGLAB_TOKEN, JWT_SECRET
docker compose up --build                      # http://localhost:8080

# Verify
curl http://localhost:8000/health
curl http://localhost:8080/api/agent/health -H "Authorization: Bearer <token>"
```

Report prepared by Farah AYARI - ESPRIT, internship at Al Baraka Bank Tunisia - Centre Urbain Nord,
supervised by Mrs. Ahlem Ben Haddoud. This document contains no account identifiers, repository URLs or credentials.
All figures are traceable to the two repositories and their frozen benchmark artifacts. | 15-20 pages | English | Governed Intelligence